

El Problema a Solucionar: Las PYMEs suelen expandir su presencia digital delegando servicios críticos en múltiples proveedores de nube (SaaS/PaaS) sin un control centralizado de activos. Esto puede llegar a generar una superficie de ataque difusa donde problemas como configuraciones por defecto, entornos de desarrollo olvidados (dev) y APIs expuestas facilitan que un atacante profile tecnológicamente a la organización y diseñe vectores dirigidos de Ingeniería Social o secuestro de subdominios, sin necesidad de siquiera tocar el perímetro principal.

 **Metodología Aplicada:** Evaluación externa de tipo Caja Negra (Black Box) basada en metodologías OSINT y reconocimiento pasivo/activo no intrusivo:

1. Reconocimiento DNS & Certificados: Enumeración de subdominios y mapeo de la infraestructura perimetral.

2. Perfilado Tecnológico: Análisis de cabeceras HTTP (curl) e identificación de sistemas de gestión de contenido (CMS WordPress) y plugins activos.

3. Auditoría de Capa de Aplicación: Evaluación de endpoints expuestos (REST API) y mecanismos de endurecimiento (Hardening).

4. Análisis de Reputación y Fugas: Auditoría de registros de correo (SPF/DMARC) y descubrimiento de exposición de credenciales corporativas externas en plataformas especializadas (haveibeenpwned.com).

 **Resultados Obtenidos (Caso de Estudio Muestra):** El objetivo evaluado, una empresa del sector entretenimiento/turismo con arquitectura perimetral híbrida (Cloudflare/GoDaddy/AWS).

Calificación de Exposición Digital: 41/100 (Riesgo Medio de acuerdo con la metodología interna).

Hallazgos Críticos:

Posibilidad de subdominio de desarrollo huérfano (dev): Error de resolución de origen (Riesgo potencial de “Subdomain Takeover”), permite tomar control de un subdominio que apunta a un servicio externo eliminado, pero del cual no se eliminó el registro DNS por olvido u omisión.

Enumeración de usuarios del sistema a través del endpoint libre “/wp-json/wp/v2/users”: Permite obtener información de usuarios del sistema facilitando actividades de reconocimiento dirigido.

Ausencia aparente de cabeceras de seguridad HTTP críticas (HSTS, CSP) en la raíz del sitio web principal, delegando la protección únicamente a la capa de login: Reduce la efectividad de una estrategia de defensa en profundidad al concentrar los controles de protección en un único punto de la aplicación.

Registro DMARC configurado en modo monitoreo (p=none) sin etiquetas de reporte activas: Monitorea intentos de suplantación interno, pero no aplica acciones de protección automáticas (eliminar, archivar, etc.).

 **Herramientas Utilizadas:** Curl (Análisis de peticiones y cabeceras HTTP). Dig / Host (Reconocimiento y análisis de registros DNS/SPF/DMARC). Herramientas de análisis de certificados SSL/TLS y subdominios. API REST de WordPress (Explotación pasiva de información). Hunter.io / HavelBeenPwned (Plataformas de descubrimiento y reputación de identidades corporativas).

Lecciones aprendidas: La delegación de servicios a terceros facilita enormemente la administración interna, pero si se ejecuta sin controles bien establecidos y una estructura definida, puede provocar la pérdida de visibilidad de los activos y configuraciones de seguridad. Es importante establecer requisitos claros desde el proceso de planeación y plasmarlos claramente en contratos de nivel de servicio bien estructurados.

Valor para la organización: Un diagnóstico temprano permite identificar activos, configuraciones y dependencias externas que podrían incrementar la exposición digital de una organización, proporcionando información útil para priorizar auditorías técnicas, revisiones de configuración y actividades de gestión de riesgos reduciendo costos de remediación.